Project Overview

Design and develop a privacy-preserving platform for sharing security incident reports among a federation of network operators (e.g., ISPs, campus networks, and enterprise networks connected to the same Internet Exchange Point) using applied cryptography. The platform supports a coordinated response to network attacks, such as DDoS campaigns, scanning activity, botnet command-and-control traffic, or BGP prefix hijacking. It must also protect the operators who report incidents from reputational exposure.

Your solution must address all security requirements below, with detailed justification of how the chosen cryptographic mechanisms provide the required properties. Several approaches discussed in class can satisfy each requirement, with different trade-offs in security, performance, and trust assumptions. For each requirement, you must justify your choice and compare it with at least one alternative you considered. You may develop a user interface of your choice.

System Operation

Member Enrollment and Revocation
Network operators join the federation through a registration process managed by the Federation Coordinator. The coordinator may revoke a member at any time (e.g., when it leaves the federation or its private keys are compromised). From that moment on, the revoked member can no longer publish, corroborate, or read new reports.

Incident Reporting
When a member detects an incident, it publishes a report that must reach all active members without revealing the reporter's identity. The report contains only:

- Incident type (e.g., DDoS, port scanning, botnet C2, prefix hijacking)
- Network indicators (e.g., source IP prefixes, ASNs, ports, protocols)
- Observation period
- Severity level and recommended mitigation (e.g., rate limiting, blackholing, filtering)

For interoperability purposes, report content must follow the JSON format below. Timestamps use ISO 8601 in UTC, and the report identifier is a random UUID generated by the reporter. Your security mechanisms may add fields around this object (e.g., signatures, timestamp tokens, or pseudonyms), but the content fields must keep this structure.

```
{
"report_id": "3f1c2a9e-7b4d-4e8a-9c21-5d6f0a1b2c3d",
"incident_type": "ddos",
"indicators": {
"source_prefixes": ["203.0.113.0/24", "2001:db8:abcd::/48"],
"source_asns": [64500, 64501],
"destination_ports": [53, 123],
"protocols": ["udp"]
},
"observation_period": {
"start": "2026-11-20T14:05:00Z",
"end": "2026-11-20T14:47:00Z"
},
"severity": "high",
"recommended_mitigation": "rate_limiting"
}
```

Allowed values:

- `incident_type`: `ddos`, `scanning`, `botnet_c2`, `prefix_hijacking`, `other`
- `severity`: `low`, `medium`, `high`, `critical`
- `recommended_mitigation`: `rate_limiting`, `blackholing`, `filtering`, `monitoring`

Corroboration
Any member who observes the same incident on their own network may anonymously corroborate a report. Corroborations are distributed to all members, so everyone can verify how many independent corroborations a report has and use that number as a confidence indicator before applying a mitigation. Each member may corroborate a given report at most once, and members cannot corroborate their own reports.

Dispute Resolution
A false report can lead other operators to drop legitimate traffic (e.g., a poisoned blocklist). Any member may open a dispute about a

report. Only the Federation Arbiter can then reveal the reporter's identity, and the reporter cannot deny authorship. The identities of corroborators remain protected.

Security Requirements

Your system must guarantee:

- **Confidentiality**: Only active federation members can read reports and corroborations. Neither the infrastructure servers nor revoked members can access their content
- **Anonymity**: Reporter and corroborator identities remain confidential to other members and to the distribution infrastructure. If any trusted entity can link members to their reports or corroborations, you must justify it explicitly and limit it to what revocation and accountability require
- **Authenticity**: Verification that reports and corroborations originate from legitimate, non-revoked members
- **Integrity**: Protection against tampering with reports and corroborations
- **Trusted timestamping**: Verifiable timestamps that establish the order of reports (e.g., who first reported an incident) and prevent the replay of old reports and corroborations
- **Accountability**: Upon a dispute, the Federation Arbiter can identify the reporter, who cannot repudiate the report
- **Unlinkability (flexible)**: Ideally, no one can tell whether two reports or corroborations were produced by the same member

The unlinkability requirement is intentionally flexible because full unlinkability is hard to reconcile with other parts of the system. For instance, preventing double corroboration requires linking corroborations that come from the same member. Revoking a member requires recognising its credentials. And if reports are linkable, revealing the author of a disputed report also reveals who wrote their other reports. You must define the level of unlinkability your system provides (e.g., none, per report, per time period, or full), justify it given the costs it involves, and discuss the residual risks of your choice.

Architecture Constraints

All reports and corroborations must be distributed to all active members, even those not affected by a given incident. Members belong to different administrative domains and may be temporarily offline, so they must be able to retrieve reports and corroborations published while they were disconnected. If necessary, you may use central servers for:

- Member registry and revocation (Federation Coordinator)
- Report and corroboration distribution (e.g., a publish/subscribe broker)
- Dispute resolution (Federation Arbiter)
- Trusted services (e.g., Certification Authorities, trusted timestamping)

Servers must be treated as honest-but-curious: they follow the protocol correctly but may try to learn the content of reports or the identities of members. Members may act maliciously, for example by forging reports, impersonating other members, or corroborating the same report more than once. All communications between clients and servers must protect the content's confidentiality and integrity.
Note that network-level metadata, such as the source IP address of a member's connection, can undermine anonymity at the application level. Your report must discuss how your architecture deals with this issue.

Deliverables

You must submit all deliverables via Blackboard by **January 8th, 2027**. Late submissions incur a 10% grade penalty for each day of delay.

- Submit all the source code clearly documented for assessment purposes.
- Submit a report of up to 10 pages that justifies in detail how your solution achieves each security requirement, the alternatives you considered, and the level of unlinkability you adopted.

Project discussion

All groups are required to attend a 20-minute evaluation session on **January 12th, 2027**. During this session, all members must take part in a discussion of the developed system with the professor. Attendance is mandatory for every student. Failure to participate will result in a final classification of “Não Admitido (NA).”